

**MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY**

**A TWO-TIER COGNITIVE ARCHITECTURE FOR
AUTOMATED THREAT DETECTION AND RESPONSE
USING AGENTIC AI**

by

Nguyen Duc Binh

A thesis submitted in conformity with the requirements
for the degree of Master of Software Engineering

**MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY**

**A TWO-TIER COGNITIVE ARCHITECTURE FOR
AUTOMATED THREAT DETECTION AND RESPONSE
USING AGENTIC AI**

by

Nguyen Duc Binh

A thesis submitted in conformity with the requirements
for the degree of Master of Software Engineering

Supervisor:
Dr. Bui Van Hieu
Dr. Dang Van Hieu

Abstract

In the modern cybersecurity landscape, Security Operations Centers (SOCs) face acute alert fatigue as continuous telemetry volume far exceeds human analyst processing capacity. Traditional automation tools relying on static playbooks lack contextual reasoning, whereas feeding raw logs directly to Large Language Models (LLMs) suffers severe latency bottlenecks, prompt injection risks, and data sovereignty violations. This thesis proposes SENTINEL, a cognitive two-tier security architecture operating fully air-gapped, coupling an LLM reasoning agent with Retrieval-Augmented Generation (RAG). Tier 1 functions as a wire-speed filter—deterministic rules, Welford anomaly scoring, and a LightGBM gate—to automatically discard baseline stream noise, while Tier 2 employs a stateful AI reasoning agent backed by MITRE ATT&CK and NIST guidance to handle complex threats behind cryptographic guardrails. Empirical evaluation on benchmark intrusion datasets demonstrates SENTINEL’s efficiency. Tier 1 and the ML Gate automatically offload **90.6%** of the incoming stream. Because the typical event never reaches the model, the median end-to-end latency falls to **0.88 ms** from **17,174.7 ms** under a single-tier LLM baseline. Delimited Nonce encapsulation neutralizes prompt injection structurally rather than by content recognition, resisting all **678** adversarial samples that the static pre-filter cannot absorb, while HMAC-SHA256 hash-chaining detects every core tampering mode and thereby guarantees audit trail integrity and tamper-evidence—though not, given its symmetric key, cryptographic non-repudiation—operating on a local workstation. SENTINEL proves that a two-tier hybrid architecture provides a trustworthy and effective paradigm for modern SOC defense.

Acknowledgments

The completion of this Master's thesis would not have been possible without the invaluable support and guidance of numerous individuals and institutions.

First and foremost, I wish to express my deepest gratitude and profound respect to my academic supervisors, Dr. Bui Van Hieu and Dr. Dang Van Hieu. Through their scholarship, precise strategic orientation, and rigorous research ethics, they devoted their time to guiding my critical thinking, offering sharp professional critiques, and inspiring my scientific curiosity throughout this research. Their mentorship has shaped this thesis into a rigorous academic work and established a foundation for my future career in cybersecurity and artificial intelligence engineering.

I am deeply grateful to the Board of Management, the leadership of the FSB School of Business and Technology, and the faculty of FPT University, whose dedicated teaching equipped me with strong theoretical and practical knowledge within a professional research environment. I also thank the Leadership and my colleagues at Department C12, the National Data Center, whose trust, flexible accommodation of my schedule, and operational insights directly informed the design and empirical validation of the SENTINEL system.

Finally, and most cherished of all, I dedicate my deepest gratitude to my beloved family, especially my dear wife and our young child. Their silent sacrifices, patience, and constant encouragement during the countless late nights of system evaluation were my pillar of strength. While every effort has been made to conduct this research with rigor, limitations inevitably remain, and I welcome all constructive feedback from the examination committee and fellow researchers.

Contents

Abstract	i
Acknowledgments	ii
List of Figures	v
List of Tables	v
List of Abbreviations	vi
1 Introduction	1
1.1 Background and Motivation	1
1.2 Research Objectives	2
1.3 Research Questions	3
1.4 Scope and Object of Study	4
1.5 Research Methodology	4
1.6 Core Contributions of the Thesis	5
1.7 Structure of the Thesis	6
2 Theoretical Background and Literature Review	7
2.1 SOC Operational Realities and Cognitive Bottlenecks	7
2.2 Online Statistical Theory and Tier 1 Machine Learning	7
2.3 Local Large Language Models and Tier 2 Agentic Intelligence	8
2.4 Adversarial AI Security and Cryptographic Log Audit	9
2.5 Overview of Related Research and Research Gaps	9
3 System Design and Technical Implementation	12
3.1 SENTINEL Architecture Overview and SOC Stack Integration	12
3.2 Tier 1: Wire-speed Filter and Machine Learning Gate	14
3.3 Tier 2: Stateful LangGraph Agent and Threat Memory	15
3.4 Dual-RAG Hybrid Knowledge Retrieval	16
3.5 Adversarial AI Security and Cryptographic Audit Sealing	16
3.6 SOC Dashboard and On-Premises Deployment Architecture	17
4 Experiments and Evaluation	18
4.1 Experimental Setup and Measurement Conventions	18
4.2 RQ1 — Offloading and Filtration Economics	19
4.3 RQ2 — AI Security Guardrails and Forensic Integrity	22
4.4 RQ3 — Stateful Reasoning and Attribution	26

5	Conclusion and Future Work	28
5.1	Summary of Research Achievements	28
5.2	Scientific and Practical Contributions	30
5.3	Limitations and Future Directions	30
	References	1

List of Figures

Figure 1.	Operational execution workflow within the SENTINEL pipeline. (Source: Author)	13
-----------	--	----

List of Tables

Table 1.	Comparative analysis between SENTINEL and existing security defense paradigms	11
Table 2.	Experimental Configuration and Dataset Role Assignment	19
Table 3.	Per-Tier Offload Rate on Two Streams with Different Base Rates . .	19
Table 4.	Throughput of Control Configurations on an Identical 150-Event Stratified Subset	22
Table 5.	Guardrail Layers, Measurement Denominators, and Results	23

List of Abbreviations

Abbreviation	Full Description
AI	Artificial Intelligence
APT	Advanced Persistent Threat
CTI	Cyber Threat Intelligence
DAPT	Dynamic Advanced Persistent Threat
FAISS	Facebook AI Similarity Search
FPR	False Positive Rate
GGUF	GPT-Generated Unified Format
HITL	Human-in-the-Loop
HMAC	Hash-based Message Authentication Code
LLM	Large Language Model
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge
NIST	National Institute of Standards and Technology
RAG	Retrieval-Augmented Generation
RRF	Reciprocal Rank Fusion
SIEM	Security Information and Event Management
SOAR	Security Orchestration, Automation, and Response
SOC	Security Operations Center

Chapter 1

Introduction

This chapter presents the research context, problem statement, and architectural foundation of SENTINEL—a Cognitive Two-Tier Architecture automating threat detection and incident response within Security Operations Centers (SOCs). By analyzing the limitations of conventional deterministic defenses, the alert fatigue crisis, and the latency and adversarial vulnerabilities inherent in Large Language Models (LLMs), it establishes the objectives, research questions, scope, methodology, and contributions of this thesis.

1.1 Background and Motivation

A modern Security Operations Center (SOC) receives millions of log events every day [2], the overwhelming majority of which are ordinary activity. For fear of missing an intrusion, monitoring systems are usually tuned to be highly sensitive, which produces still more alerts and pushes false-alarm rates past 80% [4]. As a result, a SOC's bottleneck is rarely its ability to detect. It lies in the step that follows: deciding which alert is worth a specialist stopping to examine. Human attention is the scarce resource, and it cannot be multiplied by buying more servers.

The automation currently in use does not carry that step. Perimeter filters built on static rules and fixed signatures recognize only what has been described in advance, so anything outside those descriptions is handed to a person [5]. They can classify, but they cannot explain why; and understanding the context of an alert before deciding is precisely the work the specialist is left with.

Large Language Models (LLMs) promise exactly the missing capability: to read an event

in its context and explain it in language a person understands. Placing such a model in the middle of an operational data stream, however, creates three new costs. The first is time and resources: each act of reasoning takes seconds, while data keeps arriving [18]. The second is trust: the reasoning layer itself becomes a target, because a log can carry wording an attacker composed deliberately to steer the model [9], and whatever the model concludes must be provably unaltered if it is to serve as evidence. The third is data sovereignty: internal logs typically may not leave the organization, so the model has to run on site, on finite hardware [31].

The founding observation behind this thesis is the cost gap between two kinds of decision. A decision made by a statistical rule takes less than a millisecond; a decision made by a language model takes seconds. That gap of four to five orders of magnitude makes routing every event through the most expensive tier a systematic waste, when the vast majority of events can be settled by very cheap checks. This research therefore proposes SENTINEL, a two-tier architecture built on the principle of placing cheap decisions before expensive ones: a fast filtering tier that settles most of the traffic outright, and a reasoning tier called upon only for what remains, behind protective guardrails and a sealed audit trail.

These three costs shape the three lines of inquiry pursued here, and what makes them research problems rather than merely engineering problems is that each must be measured, on real data, with metrics that cannot flatter themselves.

1.2 Research Objectives

The overarching objective of this thesis is to design, prototypically build, and empirically evaluate the SENTINEL architecture to automate network security threat detection, contextual reasoning, and incident response on local infrastructure, achieving optimal processing latency and cryptographic security.

The general objective is operationalized through three research tasks, placed in one-to-one correspondence with the three research questions in Section 1.3:

First, constructing a dual-stage stateless filtration pipeline at Tier 1 operating at wire-speed, combining Welford’s $O(1)$ online statistical algorithm, a LightGBM Machine Learning Gate, and a Tier 1.75 Semantic Cache so that the majority of telemetry is resolved at the cheap tier without consuming GPU compute resources.

Second, designing a structural protection mechanism for the Tier 2 language model via Delimited Data Encapsulation using random cryptographic nonces, an output action guardrail, and an HMAC-SHA256 log audit chain to neutralize prompt injection attacks and guarantee the integrity and tamper-evidence of forensic records.

Third, developing a stateful reasoning engine based on a LangGraph agent state-graph coupled with persistent Threat Memory and a Dual-RAG retrieval system (combining FAISS vector search and BM25 sparse keyword matching) integrated with a STIX-aligned MITRE ATT&CK knowledge base, enabling evidence-cited forensic justification, detecting and neutralizing hallucination via a deterministic RAG-anchoring guardrail, and accurately triaging the work that must be routed to a human analyst.

1.3 Research Questions

The design and empirical evaluation process of this thesis are guided by three strategic research questions:

The first research question (RQ1) addresses pipeline efficiency and filtration economics: How can a multi-tiered architecture be designed to autonomously offload security telemetry at wire-speed, thereby addressing the latency bottlenecks and resource consumption inherent in Large Language Models?

The second research question (RQ2) addresses AI security boundaries and forensic integrity: What methodologies and security mechanisms can effectively withstand adversarial risks (such as log-substrate prompt injection) to protect the AI’s reasoning flow, while simultaneously ensuring the integrity and tamper-evidence of forensic audit trails?

The third research question (RQ3) addresses stateful agent reasoning and technical attribu-

tion: How can stateful reasoning capabilities and domain-specific knowledge retrieval be integrated into an AI Agent to automate intrusion analysis, attribute attack techniques, and generate transparent forensic reports, thereby reducing and accurately triaging the workload requiring human analysts?

1.4 Scope and Object of Study

The primary subject of study is the SENTINEL Two-Tier Cognitive Architecture, comprising the Tier 1 stateless filter (online Welford statistics and LightGBM Machine Learning Gate), Tier 1.75 Semantic Cache, Tier 2 stateful agent engine (LangGraph state-graph and Q4_K_M quantised Foundation-Sec-8B-Instruct hosted locally via llama.cpp), Dual-RAG retrieval system (combining FAISS and BM25) integrated with MITRE ATT&CK knowledge, and cryptographic security controls including Delimited Nonce Encapsulation and HMAC-SHA256 log audit chains.

The empirical evaluation rests on **two primary datasets**: CSE-CIC-IDS2018 for wide-area network telemetry and CSIC 2010 for real-world HTTP Layer 7 attacks. Two supplementary sources—DAPT2020 for multi-stage intrusion chains and a zero-day sample set—are included as **proof-of-concept** evidence only and support no contribution claim. Adversarial evaluation uses 703 samples from three published corpora (AdvBench, deepset, jack-hhao) as the headline denominator, plus 80 author-composed samples reported separately. The system is deployed on a single local workstation (NVIDIA RTX 4060 Ti 16GB VRAM, Intel Core i7, 32GB RAM) operating fully air-gapped. Automated responses are restricted to blocking IP addresses, logging, or escalating to analysts; physical infrastructure interventions are out of scope.

1.5 Research Methodology

This thesis adopts the Design Science Research (DSR) methodology across three pillars: the statistical and machine learning pillar (Welford $O(1)$ online statistics for rolling Z -score

anomaly detection with LightGBM classification); the agentic logic pillar (a LangGraph acyclic state-graph orchestrating language model reasoning with hybrid FAISS/BM25/RRF retrieval); and the adversarial security pillar (stress-testing prompt injection resilience and verifying forensic log integrity). Efficacy is evaluated using a 5D Metrics Framework covering classification quality, processing performance, adversarial resistance, explanation coherence scored by an independent judge model, and audit integrity. Three methodological principles are enforced throughout: (i) **the denominator must match the question**—distribution-dependent metrics are measured on the live stream while classification quality is measured on a class-balanced set; (ii) metrics use base-rate-immune measures (MCC, Balanced Accuracy) rather than Accuracy or binary $F1$; and (iii) every ratio is reported with its denominator and measurement coverage.

1.6 Core Contributions of the Thesis

This thesis contributes three core values to the fields of cybersecurity and artificial intelligence.

In system architecture, the research proposes and quantifies the principle of *placing cheap decisions before expensive ones*, and further demonstrates by measurement that the offload rate is a **function of the attack base rate of the stream**, not a constant of the system—a property not stated explicitly in the related literature.

In AI security, it contributes a structural defense based on Delimited Data Encapsulation with random cryptographic nonces. The essential point is that this guarantee **does not depend on the block rate of any classifier**: encapsulated content is processed as passive text regardless of what it says, unlike probabilistic semantic filters whose effectiveness degrades against novel variants.

In agentic logic and security knowledge, it replaces rigid SOAR playbooks with a stateful LangGraph agent graph over a 433-item STIX-aligned MITRE ATT&CK knowledge base and persistent Threat Memory, coupled with a deterministic RAG-anchoring

guardrail requiring every emitted technique identifier to be present in that batch’s retrieved documents—turning hallucination control from a hope placed in the model into a verifiable architectural constraint.

1.7 Structure of the Thesis

Chapter 2 systematizes the theoretical foundations and surveys related work to establish the research gap. Chapter 3 details the technical design of SENTINEL. Chapter 4 presents the quantitative results, organized to follow the three research questions. Chapter 5 synthesizes findings, acknowledges limitations, and outlines future directions.

Chapter 2

Theoretical Background and Literature Review

This chapter outlines the theoretical principles and literature review underlying the thesis: SOC operational bottlenecks, Tier 1 statistical and machine learning foundations, Tier 2 stateful agent and local LLM architectures, adversarial threats with cryptographic audit mechanisms, and a survey of existing AI Security systems delineating the research gap addressed by SENTINEL.

2.1 SOC Operational Realities and Cognitive Bottlenecks

Security monitoring in modern SOC's relies on aggregating raw telemetry from Next-Generation Firewalls, Intrusion Detection Systems, and Endpoint Detection and Response agents into centralized SIEM platforms [2], at volumes far exceeding human analysis capacity [3]. Because perimeter devices operate on static signatures and deterministic rulesets, relaxing alert thresholds to avoid missing threats produces an alert volume crisis with false positive rates exceeding 80% [4] and consequent analyst alert fatigue. SOAR platforms automate response workflows but depend on rigid pre-programmed playbooks that lack contextual reasoning when confronted with novel attack variants [5].

2.2 Online Statistical Theory and Tier 1 Machine Learning

To filter high-density telemetry streams at wire-speed without maintaining full historical logs in memory, Welford's algorithm maintains $\mathcal{O}(1)$ time and memory complexity [6].

Sample mean μ_k and sum of squared deviations S_k are updated via recurrence relations:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad S_k = S_{k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.1)$$

enabling real-time standard deviation $\sigma_k = \sqrt{S_k/(k-1)}$ and continuous Z -score anomaly evaluation without retaining the raw event series. Concurrently, the LightGBM machine learning gate utilizes leaf-wise tree growth and histogram feature binning to achieve sub-third-of-a-millisecond inference per sample. To counter machine learning evasion attacks, the ML Gate enforces Z -score feature clipping within $\pm 8\sigma$ and baseline mean imputation. Additionally, the Tier 1.75 Semantic Cache hashes normalised query strings in RAM, reusing adjudications across events that reduce to the same description and short-circuiting the pipeline before any GPU invocation.

2.3 Local Large Language Models and Tier 2 Agentic Intelligence

Local LLM deployment demands strict memory optimization: Foundation-Sec-8B-Instruct in FP16 precision consumes approximately 18 GB VRAM [23]. Weight quantization maps floating-point parameters to integer grids [19]. Using GGUF Q4_K_M format via `llama.cpp`, required VRAM drops to 7–8 GB (>50% savings) without significant accuracy loss, operating on a single 16 GB GPU.

To orchestrate reasoning, Tier 2 employs a LangGraph acyclic state graph [8] integrated with Threat Memory. To prevent hallucination, the system integrates Retrieval-Augmented Generation (RAG) [7] via a Dual-RAG architecture combining FAISS dense search [20] and BM25 sparse search [21], fused via Reciprocal Rank Fusion (RRF) [11]:

$$RRF_Score(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (2.2)$$

retrieving context directly from 433 STIX MITRE ATT&CK technique entries and NIST SP 800-61r2 guidance for forensic justification.

2.4 Adversarial AI Security and Cryptographic Log Audit

Integrating LLMs introduces log-substrate prompt injection risks [9], where attackers inject malicious instructions into User-Agent headers or Syslog strings to hijack AI reasoning [30]. The defining property of this vector is that **log content is authored by the attacker**: any defense based on recognising malicious content is an unending race against novel phrasings. To neutralise the vector structurally, SENTINEL applies Delimited Data Encapsulation with random nonce tags isolating raw inputs, combined with deterministic guardrails constraining outputs to three valid actions (BLOCK_IP, LOG, AWAIT_HITL).

To protect forensic records, the system uses HMAC-SHA256 signature chaining [29] to seal audit records with a local secret key, producing a tamper-evident audit trail. The scope of this guarantee must be stated precisely: because HMAC uses a **shared symmetric key**, the mechanism establishes **integrity and tamper-evidence**, but does **not** constitute non-repudiation in the cryptographic sense—that property requires asymmetric signatures. This boundary is respected throughout the thesis.

2.5 Overview of Related Research and Research Gaps

Artificial intelligence research applied to Security Operations Centers has evolved across three architectural paradigms [15].

Traditional enterprise defense comprises SIEM platforms such as IBM QRadar and SOAR systems such as Palo Alto Cortex XSOAR [2, 5]. QRadar correlates telemetry with static rules and exhibits high false positive rates (>80%) from a lack of contextual comprehension; Cortex XSOAR automates response via playbooks and fails on variants outside them. The strength of this paradigm is very low latency—precisely the property SENTINEL’s Tier 1 inherits rather than discards.

Cloud-based LLM agent systems are represented by Watchtower [12] and Cyber-RAG [13]. Watchtower transmits raw telemetry to commercial cloud LLMs, incurring

quadratic self-attention latency $\mathcal{O}(N^2)$ of 4–26 seconds per event and violating Zero-Trust and data sovereignty mandates [31]. CyberRAG focuses on single-tier RAG retrieval; lacking a wire-speed filter it suffers queue exhaustion, and it lacks stateful correlation for multi-stage campaigns.

Autonomous planning and reasoning agents comprise AutoBnB [14], LanG Agentic SOC [16], and Policy-Guided SIEM [17], which combine Bayesian planning, governance-aware multi-agent orchestration, and rule-guided guardrails over Splunk workflows respectively. While these advance multi-agent coordination, they remain single-tier architectures in which every event traverses an LLM reasoning node; published average latency consequently remains between 480 ms and 520 ms on 16–24 GB VRAM infrastructure.

The research gap is therefore: **no hybrid architecture simultaneously satisfies three requirements**—(1) resolving the majority of telemetry at the statistical/ML tier under one millisecond; (2) stateful cognitive reasoning running locally on a 16 GB GPU with RAG-anchored hallucination control; and (3) structural model-integrity protection via Delimited Nonce encapsulation and HMAC-SHA256 forensic sealing. Table 1 contrasts SENTINEL against these paradigms.

Table 1. Comparative analysis between SENTINEL and existing security defense paradigms

Evaluation Metric	SIEM / SOAR (QRadar, XSOAR)	SOTA Agents (Watchtower, LanG, AutoBnB)	SENTINEL Architecture (Thesis)
Core Technology	Static correlation rules, rigid Python/JS playbooks	Cloud Multi-Agent LLMs / Local Multi-Agent RAG	Welford $\mathcal{O}(1)$ + LightGBM T1, LangGraph Agent T2
Operational Goal	Centralized log aggregation and playbook response	Automated incident investigation via LLM reasoning	Resolve traffic at the cheap tier, reserve the expensive tier for cases needing reasoning
Cost Tiering	One cheap tier, no reasoning	One expensive tier, every event reaches the LLM	Two tiers: cheap first, expensive second
Data Sovereignty	Local enterprise	Cloud leakage risk or 24GB GPU requirement	100% air-gapped on a 16 GB GPU
Prompt Inj. Defense	Not applicable	Probabilistic semantic filters (evadable)	Structural guarantee, independent of payload content
Forensic Audit	Standard text logs (editable post-compromise)	No cryptographic sealing	HMAC-SHA256 chain, tamper-evident

Chapter 3

System Design and Technical Implementation

This chapter details the architectural design and implementation of SENTINEL: the two-tier execution pipeline, Tier 1 wire-speed filtration and Machine Learning Gate, the Tier 2 agentic reasoning engine and Threat Memory, Dual-RAG knowledge retrieval, adversarial security controls with cryptographic audit sealing, and the local deployment architecture.

3.1 SENTINEL Architecture Overview and SOC Stack Integration

SENTINEL enforces a Cognitive Two-Tier Architecture whose core design principle is strict decoupling of work by cost: Tier 1 executes stateless statistical and machine learning algorithms resolving the majority of traffic at wire-speed, while Tier 2 hosts a stateful language model agent performing deep contextual reasoning for complex anomalous events.

Figure 1 illustrates the execution flow. Raw telemetry from perimeter sources (NGFW, IPS, EDR) is ingested into a Redis Stream queue. On arrival, Tier 1 computes online Z -score metrics using Welford's running statistics and classifies feature interactions through the LightGBM Machine Learning Gate. Flows conforming to baseline distributions, or matching query templates already held in the Tier 1.75 Semantic Cache, are adjudicated sub-millisecond without touching the GPU.

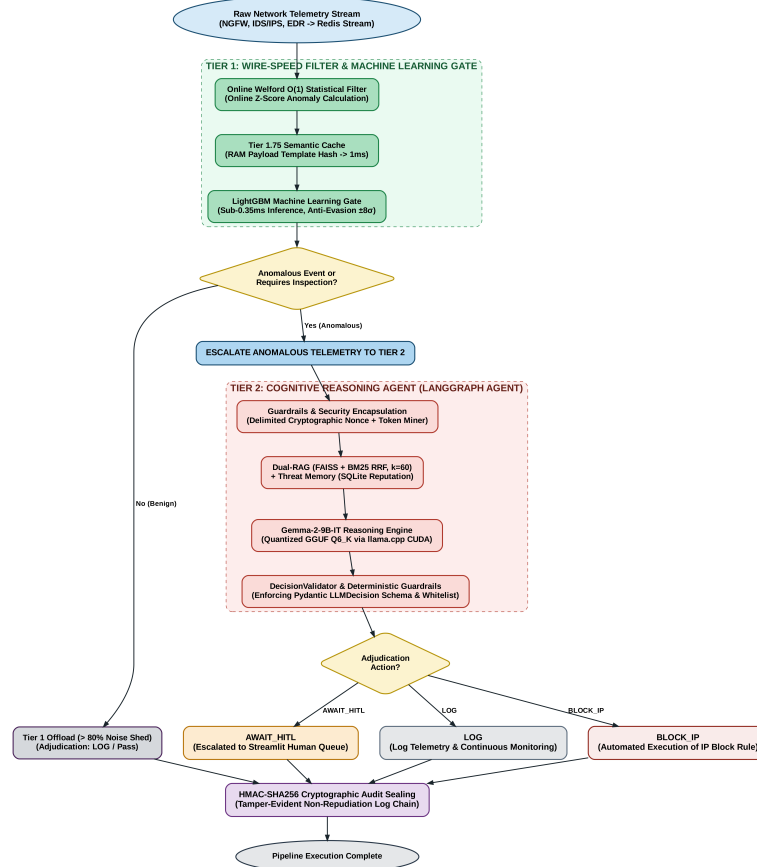


Figure 1. Operational execution workflow within the SENTINEL pipeline. (Source: Author)

One design decision must be stated explicitly: among Tier 1's action vocabulary, **only ESCALATE proceeds to Tier 2**. The adjudications BLOCK_IP, ALERT, AWAIT_HITL, and DROP all **terminate at Tier 1**. This is the basis for the offload definition used in Chapter 4: an event counts as offloaded when it generates no language model invocation, regardless of whether the final adjudication was to block or to pass.

At Tier 2, the LangGraph agent triggers a reasoning cycle on the locally hosted Foundation-Sec-8B-Instruct model, integrating historical state from Threat Memory and retrieved evidence from Dual-RAG. Final decisions are governed by a deterministic guardrail bounded to three states, and every record is sealed with an HMAC-SHA256 hash chain. Within an enterprise SOC, SENTINEL therefore acts as cognitive middleware between the SIEM collector and downstream firewall/SOAR execution platforms: it absorbs stream noise at Tier 1 and supplies grounded, cited justifications for escalated events, while guaranteeing

data sovereignty through fully air-gapped execution on a single 16 GB VRAM GPU.

3.2 Tier 1: Wire-speed Filter and Machine Learning Gate

Tier 1 is the stateless perimeter layer, combining the Welford $\mathcal{O}(1)$ statistical baseline filter (Equation 2.1) with a LightGBM Machine Learning Gate to guarantee millisecond latency before any GPU invocation.

The statistical filter computes $Z = (x - \mu)/\sigma$ in real time across flow attributes (packet rates, flow volumes, connection durations), with μ and σ updated via the recurrences of Section 2.2 without retaining raw series [6]; traffic conforming to the baseline is shed immediately. Alongside this statistical branch, Tier 1 operates an application signature set covering **29 web attack families** with multi-round normalisation in the OWASP CRS style—decoding URL and HTML entities before matching—to catch payloads disguised by encoding. For repetitive volumetric behaviour, the Tier 1.75 Semantic Cache hashes normalised query strings in RAM and reuses existing adjudications.

A LightGBM Gradient Boosted Decision Tree model follows, evaluating non-linear feature interactions. It uses leaf-wise growth and is trained on 949,535 NetFlow samples (664,674 training, 189,907 hold-out). To neutralise evasion, the Gate clips feature Z -scores within $\pm 8\sigma$ and imputes missing values with baseline means; if distorted feature proportions exceed 30%, it **abstains** and escalates. Abstention is deliberate: a confident wrong answer is more dangerous than an admission of ignorance, because it causes the system to act autonomously with no one reviewing. Gate adjudications map to actions through a unified **four-band confidence policy** (0.85 / 0.65 / 0.40 for BLOCK_IP / ESCALATE / ALERT / LOG), so that confidence *drives* the action rather than merely accompanying it, and autonomous blocking is isolated to the top band, which additionally requires Tier 1 rule concurrence.

3.3 Tier 2: Stateful LangGraph Agent and Threat Memory

Tier 2 performs stateful cognitive reasoning, executing a GGUF Q4_K_M quantized Foundation-Sec-8B-Instruct model [23] via CUDA-compiled llama.cpp on a single 16 GB VRAM GPU, cutting required VRAM from 18 GB (FP16) to 7–8 GB with negligible accuracy loss.

Reasoning is orchestrated by a LangGraph state-graph [8] across five nodes: guardrail inspection, context enrichment (`rag_context`), triage (`llm_triage`), technique mapping (`attack_mapper`), and action execution or hand-off to `human_in_loop`. Technique mapping requires explicit verification from domain knowledge; absent an unambiguous match, the graph routes to analyst review (`AWAIT_HITL`) rather than emitting a speculative action. The human-review path **is a designed output, not a failure**: the system triages the work requiring a human rather than eliminating the human. At `llm_triage` the system performs **label stripping**, removing every internal classification field from the prompt—a precondition for the validity of every measurement in Chapter 4, since a ground-truth label reaching the context would let the model copy the answer rather than reason to it.

To correlate traces over time, Tier 2 maintains Threat Memory on an index-optimized SQLite database configured with `synchronous=NORMAL` and `rollback-journal` rather than `WAL`, preventing cross-UID file lock crashes under Docker. It tracks IP reputation (`ip_reputation`), internal entities (`known_entities`), risk indicators (`apt_indicators`), and threat events (`threat_events`). Reputation score S decays over silent period t :

$$S_{\text{new}} = S_{\text{old}} \times (1 - \lambda)^t \quad (3.1)$$

where λ is the decay rate. On reaching the maximum ($S = 100$), Tier 1 enforces block-on-sight for subsequent connections without re-triggering Tier 2—closing an automated feedback loop that converts a one-time reasoning cost into a reusable adjudication. Internal infrastructure addresses are whitelisted and immune to blocking, preventing self-DoS.

3.4 Dual-RAG Hybrid Knowledge Retrieval

To limit hallucination and ground security decisions, Tier 2 incorporates a Dual-RAG retrieval system over 433 STIX 2.1-structured MITRE ATT&CK entries [24] and NIST SP 800-61r2 guidance [10]. Retrieval runs two complementary mechanisms: dense semantic search via FAISS [20] with a Sentence-BERT embedding model [25], identifying techniques sharing semantic intent despite keyphrase variation; and sparse keyword matching via BM25 [21], ensuring exact retrieval of identifiers such as CVE codes, Registry keys, or service ports. Candidates are consolidated using RRF (Equation 2.2) with $k = 60$ and injected into the prompt at `rag_context`.

On top of retrieval the system applies an **evidence-anchoring guardrail**: every technique identifier emitted by the model is checked back against that batch’s retrieved documents, and identifiers absent from them are forced to N/A and routed to `AWAIT_HITL`. This is a **verifiable architectural constraint** rather than a dependency on how prone a given model is to hallucinate—and it is precisely what separates a knowledge-grounded system from a wrapper around a language model.

3.5 Adversarial AI Security and Cryptographic Audit Sealing

Log-substrate prompt injection [9] embeds control instructions inside raw telemetry fields (User-Agent headers, URI parameters, Syslog text) to hijack model behaviour. SENTINEL implements Delimited Data Encapsulation with a cryptographic nonce regenerated per processing batch [30]: raw telemetry is enclosed within nonce-bearing delimiters, forcing the model to treat the enclosed content as passive data. Per-batch generation—rather than a fixed delimiter—is essential, because an invariant delimiter can be inferred from source code or repeated observation, at which point an attacker can close the encapsulation and escape it. In parallel, a deterministic guardrail enforces Pydantic schema validation (`LLMDecision`); on formatting errors, regular expression salvaging recovers essential fields or defaults to the safe `AWAIT_HITL` state.

For auditing, each adjudication record i is chained using HMAC-SHA256 [29]:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.2)$$

where D_i is the current record, H_{i-1} the preceding hash, and K a local secret key loaded from the environment rather than hardcoded, since a key exposed in source allows the entire chain to be forged from scratch. Chaining ensures any alteration or deletion within the chain breaks continuity and is flagged immediately. As stated in Section 2.4, this guarantees **integrity and tamper-evidence**; because the key is symmetric, it does not constitute non-repudiation in the cryptographic sense.

3.6 SOC Dashboard and On-Premises Deployment Architecture

The SOC Analyst Dashboard is built with Streamlit, connecting directly to Redis Stream and Threat Memory to provide real-time visibility: the per-tier offload funnel, multi-stage intrusion timelines, HMAC chain integrity status, and the Human-in-the-Loop review panel. All services are containerized with Docker Compose; `llama.cpp` is compiled with CUDA for the RTX 4060 Ti; and `threat_memory.db` with the FAISS index are mounted on persistent volumes so reputation scores and audit records survive restarts.

Deployment adheres to Zero Trust mandates [31]: password strings in `REDIS_URL` are redacted before logging. To manage stream surges, backpressure is driven by **Redis consumer group lag** rather than queue length. This choice is mandatory: a Redis Stream's length only grows over time even when every record has been fully processed, so using it as the throttling signal would strangle the producer permanently; only consumer group lag reflects the work actually outstanding.

Chapter 4

Experiments and Evaluation

This chapter presents the quantitative experimental results for the SENTINEL system, organized to follow the three research questions posed in Chapter 1. Each section states the measured metric, the denominator of the measurement, and the limits of the conclusion it supports.

4.1 Experimental Setup and Measurement Conventions

The system is deployed on a local server representative of small-to-medium enterprise SOC infrastructure, with all microservices containerized via Docker Compose in an air-gapped environment. The governing methodological principle is that **the denominator must match the question**: distribution-dependent metrics (offload rate) are measured on the live stream, while classification quality is measured on a class-balanced set. Conflating the two is a serious source of error—measuring offload on a forced 50/50 set yields an artificially low figure, because that set does not reflect the distribution the system actually encounters. Table 2 states each dataset’s role.

Two further conventions apply to every run. First, dynamic rules are **frozen** during measurement, preventing a run from generating rules and then benefiting from them later. Second, the 50 author-composed samples embedded in `ground_truth.json` are excluded from all ratios—if retained, they constitute 16.7% of the attribution scoring set and all share a single answer, skewing the label distribution.

Table 2. Experimental Configuration and Dataset Role Assignment

Component	Specification	Role in the Measurement
Processor (CPU)	Intel Core i7	Welford filtering and Redis streams
System RAM	32 GB DDR5	Semantic Cache and FAISS indices
Graphics Card (GPU)	RTX 4060 Ti 16 GB	llama.cpp CUDA, Foundation-Sec-8B
Virtualization	Docker Compose	Air-gapped, reproducible environment
datatest.json	4,240 samples, 51.8% attack	ML Gate classification quality. Not used for offload rate
ground_truth.json	1,750 samples → 1,700 when scored	Ablation, reasoning quality. 50 author-composed samples excluded from all ratios
build_stream()	25,799 (150 warm-up + 25,649 scored), 31.6% attack	Offload rate, end-to-end
SOC-like stream	99,717 events, 9.8% attack	Offload rate at a near-realistic base rate
Adversarial set	823 samples, of which 703 from published corpora	AdvBench, deepset, jackhhao. Author-composed portion reported separately

4.2 RQ1 — Offloading and Filtration Economics

RQ1 has three components: offloading at wire-speed, reducing latency, and reducing resource consumption. As stated in Section 3.1, an event counts as **offloaded** when it generates no language model invocation—every action other than `ESCALATE` terminates at Tier 1. This definition matters because a counting scheme crediting only `DROP` omits `BLOCK_IP`, `ALERT`, and `AWAIT_HITL`, none of which consume a single token.

Table 3. Per-Tier Offload Rate on Two Streams with Different Base Rates

Resolving Tier	Benchmark stream, 25,649 ev		SOC-like stream, 99,717 ev	
	Events	Share	Events	Share
Tier 1 (rules + Welford + signatures)	20,663	80.6%	38,207	38.3%
Machine Learning Gate (4-band)	2,568	10.0%	58,992	59.2%
Cumulative — never reaches LLM	23,231	90.6%	97,199	97.5%
Remainder → Tier 2 (LLM)	2,418	9.4%	2,518	2.5%
<i>Attack base rate of the stream</i>		<i>31.6%</i>	<i>9.8%</i>	

Table 3 reveals a property not stated explicitly in the related literature: **the offload rate**

is a function of the stream’s attack base rate, not a constant of the system. Within a single stream the aggregate decomposes linearly as $\text{offload}(p) = (1 - p) \cdot \text{offload}_{\text{benign}} + p \cdot \text{offload}_{\text{attack}}$, where p is the attack rate. On the benchmark stream the two per-label rates are **92.35%** on benign cases and **86.72%** on attack cases, which reproduce the measured 90.6% exactly; on the SOC-like stream they are **97.88%** and **93.77%**, reproducing 97.5%. The coefficients themselves differ between the two streams because the streams differ in composition, so the relation licenses projection to a different base rate **within a stream**—not transfer of one stream’s coefficients onto another. The 90.6% figure is therefore **not an architectural ceiling** but a consequence of a test stream deliberately loaded with more than three times the realistic attack proportion.

A second observation: **the tier carrying the load changes with the stream.** On the benchmark stream, Tier 1 rules resolve 80.6%; on the benign-dominated stream, the ML Gate becomes the primary carrier at 59.2%. The two tiers compensate for one another rather than overlapping—empirical justification for retaining both.

Per-component savings. The ML Gate processes each feature vector in **0.287 ms**, achieving **3,452 events/second**. The Tier 1.75 Semantic Cache achieves an **81.3%** hit rate (1,220 of 1,500 queries) with an **8.9×** speed-up and zero evictions; its key is a hash of the normalised query string—exact match, not embedding similarity—so hits arise because many distinct events reduce to the same service/port/technique description. One quality figure belongs in this section rather than beside it, because it is the guard condition on the offload claim itself: a 90.6% offload rate would read equally well as "passes almost everything" if the offloaded portion were not adjudicated correctly. On the balanced `datatest.json` the Gate attains **MCC 0.667** and Balanced Accuracy 0.833—MCC deliberately in place of Accuracy, since a system answering "benign" everywhere already scores 74% Accuracy on a skewed stream while discriminating nothing—and its **autonomous blocking** subset of 962 actions achieves **100% Precision with zero false positives**. That last condition is mandatory: offloading that blocks genuine customers is not efficiency but loss.

Tier 2 → Tier 1 feedback loop. A fourth offload mechanism is verified by a two-round

experiment on a fixed seed. After harvesting 598 rules from the ML Gate’s blocking adjudications, the escalation rate falls from **20.28% to 17.98%** (a relative reduction of **11.35%**, or 594 additional events absorbed by Tier 1), while detection quality **improves** rather than degrades: MCC +0.0378, Recall +0.0452. This is noteworthy because learn-from-adjudication mechanisms typically trade accuracy for speed; here both improve.

End-to-end latency. Latency is measured on 500 events sampled strided from `build_stream()`, preserving the real benign/attack ratio rather than forcing a balanced set. Mean end-to-end latency falls from **17,187.9 ms** (single-tier LLM) to **5,286.7 ms**, a reduction of **69.2%**, with the difference statistically significant under a Mann-Whitney U test ($p \approx 9 \times 10^{-57}$). The median is far more striking: **0.88 ms** against **17,174.7 ms**, a factor of roughly **19,500**—because the typical event never reaches the LLM at all. Per-stage means confirm the cost asymmetry motivating the architecture: **0.182 ms** at Tier 1, **0.924 ms** at the ML Gate, and **22,785 ms** when the LLM is invoked.

One result must be reported against interest: the **95th percentile is worse** for the two-tier system—**25,829 ms** versus **21,434 ms** for the LLM-only baseline. The cause is structural: an event that does escalate has already paid the Tier 1 and ML Gate cost before paying the LLM cost. The tail is therefore genuinely slower, and the architecture’s benefit is concentrated in the median rather than distributed uniformly. Reporting mean and median without the tail would misrepresent the trade-off. For resources, the thesis reports **LLM invocations avoided** (97,199 of 99,717 events) rather than a VRAM reduction percentage, because no VRAM measurement was performed.

Comparison against control configurations. To answer "faster than what", four control configurations are measured on an **identical 150-event stratified subset** (Table 4), rather than importing headline figures from other publications—an invalid comparison across differing datasets and metric definitions.

SENTINEL’s deterministic path runs **more than 20,000×** faster than routing every event to the language model (measured $20,531\times$). Static signatures are faster still, at roughly three times SENTINEL’s rate, which is expected—they perform no statistical or model inference.

Table 4. Throughput of Control Configurations on an Identical 150-Event Stratified Subset

Control Configuration	Throughput
H1 — Static signatures, 29 WAF families	11,129 ev/s
SENTINEL — Tier 1 + ML Gate	3,860 ev/s
H2 — Single-tier LightGBM, flat threshold	2,162 ev/s
H3 — Single-tier LLM (identical data, model, and prompt)	0.19 ev/s

The ordering *is* the architectural argument in one line: each tier costs what it costs, and the design question is how much traffic can be settled before the expensive one is reached. Two of these figures must not be combined: the 0.19 ev/s routes each event through the **full Tier 2 agent** (797.9 s for 150 events), whereas the 17,187.9 ms baseline is a **bare model call** on the raw log with no token ceiling and no output schema. They describe different single-tier designs, not one measurement in two units. Finally, surge-load testing on the 99,717-event stream confirms that consumer-group lag-based backpressure keeps RAM and VRAM utilisation stable, guaranteeing continuous availability.

4.3 RQ2 — AI Security Guardrails and Forensic Integrity

Threat model and measurement convention. RQ2 names log-substrate prompt injection as a *typical* adversarial risk, not as the scope. SENTINEL is therefore evaluated against **two structurally different attack surfaces**. The first attacks **through language**: injection and jailbreak text embedded in telemetry fields, aimed at the Tier 2 language model; resistance means the embedded instruction fails to change the agent’s action. The second attacks **through feature space**: extreme or infinite values injected into flow attributes to force the LightGBM Gate to answer "benign"; resistance means a distorted sample is still not flipped to benign. A defence covering only the first surface is a narrow defence, since the two tiers are attacked by entirely different means.

Three conventions make the ratios interpretable. First, the static verdict is the logical OR of **three separate detectors**—pattern matching, encoding neutralisation, and delimiter stripping—each recorded individually, so that a failure can be *located* rather than merely

counted. Second, a **negative control is mandatory**: the same detectors run over 230 benign logs, because a layer that flags everything also achieves "100% blocking", and a block rate quoted without its false-flag rate is uninterpretable. Third, following Section 4.1, published-corpus and author-composed samples are **scored separately and never merged into one headline**.

Table 5. Guardrail Layers, Measurement Denominators, and Results

Guardrail layer	Denominator	Result
<i>Tier 1 — attack through language</i>		
Static pre-filter, published corpora	703 samples	132 → 18.8%
by detector: pattern / encoding / delimiter	703	114 / 29 / 0
Static pre-filter, author-composed	80 samples	58 → 72.5%
Static pre-filter, cross-check set	40 samples	2 → 5.0%
Static pre-filter — false flags on benign logs	230 benign logs	46 → 20.0%
of which: encoding-detection layer	46/46	all of them
<i>Tier 1 — attack through feature space</i>		
ML Gate — evasion, hard mode (all features distorted; 13 flipped, 95% CI 97.86–99.27)	1,036 detected attacks	1,023 → 98.75%
ML Gate — single-feature modes (∞ / extreme)	$1,036 \times 2$	100% both
ML Gate — abstention on distorted input	4,236 events	116 → escalate
<i>Tier 2 — structural guarantee</i>		
Delimited nonce encapsulation	678 hard samples, coverage 100%	678 → 100%
Schema validation under forced backend failure	1 induced failure	AWAIT_HITL, no crash
Determinism (same seed, 5 runs)	5 runs	identical actions
Seed-only variation	10 samples	0 flipped
Context-overflow guard	16,384-token window, 4,000-token budget	worst case 1,655
<i>Forensic integrity</i>		
HMAC — three core tampering modes	30 trials each	100%
HMAC — negative control (intact chain)	450 records	no false alarm
HMAC — tail truncation	—	0% — undetectable

Tier 1 against language. On published corpora the static pre-filter blocks **18.8%**, and that figure must be read together with the **20.0%** false-flag rate on benign logs. Per-detector analysis localises the problem precisely: all 46 false flags originate in the encoding-detection layer, while pattern matching and delimiter stripping produce none—an actionable finding about one layer, not a verdict on the guardrail. The cost of a false flag is also bounded and must be stated, since 20% sounds alarming without it: a static flag raises the isolation level and annotates the record, but does **not** drop the event or block the source. It is therefore a rate of unnecessary annotation, not of benign traffic denied service. The

author-composed subset blocks at 72.5%, far above the published figure, and the gap is explained rather than excused: 45 of those 80 samples are encoding-bypass cases and the encoding neutraliser was built precisely for them. Reporting the merged 23.3% would have flattered the system by counting samples written with knowledge of the defence; **18.8% is the figure the thesis stands behind.**

Tier 1 against feature space. The ML Gate clips Z -scores to $\pm 8\sigma$, imputes missing values from the baseline, and abstains when the distorted-feature proportion exceeds 30%. Under the **hard mode**, in which *every* feature of a detected attack is driven to an extreme, **98.75%** of samples resist (1,023 of 1,036; 95% CI 97.86–99.27), with 13 flipped to benign. The two single-feature modes reach 100%, and the thesis cites the hard mode rather than an average across all three, because averaging in two trivially saturated modes would inflate the figure past what the defence has actually demonstrated. Abstention is counted as a guardrail outcome, not a failure: 116 events were escalated instead of guessed, since a confident wrong answer causes autonomous action with no one reviewing.

Tier 2 and the categorical difference. The static layer is an inexpensive pre-filter; the security guarantee comes from **Delimited Data Encapsulation**, which is structural—content inside the nonce-bounded region is processed as passive text *regardless of what it says*. It was evaluated on **all 678 samples of the seven categories the static layer does not absorb**, at **100% coverage** of that set. This is a superset of the 543 samples that genuinely bypassed the static layer within those categories, so the test is stricter than required rather than favourably sampled; Tier 2 resisted **678 of 678**. That is the categorical difference: a classifier blocking $x\%$ always leaks $(100 - x)\%$ and degrades against novel variants, whereas a structural guarantee does not depend on recognising malicious content at all. The 18.8% therefore **does not contradict** the thesis—it quantifies how much work the structural layer must absorb. Two robustness controls support every LLM-dependent measurement in this chapter: under a fixed seed across five runs the agent emitted **identical actions**, and varying only the seed across ten samples flipped **no adjudication**, so differences between configurations cannot be dismissed as decoder noise. A forced backend failure degraded to `AWAIT_HITL` rather than crashing or defaulting to a permissive action.

How tampering is detected. Verification recomputes the entire chain from the genesis record under $H_i = \text{HMAC}(D_i \parallel H_{i-1}, K)$. Because each link consumes its predecessor's hash, a single byte altered in D_j invalidates *every* link from j onward, so detection is **positional** rather than a bare "something changed". The three core modes map onto the three ways continuity can be broken: a **content edit** makes the recomputed hash at j disagree with the stored one; an **inserted forged record** has no valid predecessor to chain back to; a **deleted middle record** leaves H_{j+1} referencing a hash that no longer exists. All three are detected in 30 of 30 trials, and the negative control over 450 intact records raises no false alarm. The measurement ran with a key loaded from the environment, not the in-source default—a key visible in source would let the whole chain be forged from scratch and would void every rate above. The thesis states the blind spot proactively: **tail truncation is undetectable**, an inherent property of log-chaining, since deleting trailing records leaves no subsequent link against which to verify. The remedy is periodic anchoring of hash values outside the system.

Guardrails that do not reduce to a single ratio. Several controls defend paths that no block-rate captures. The `RAG_Sanitizer` guards the knowledge base at both ingestion—NFKC normalisation against homoglyphs, removal of control and zero-width characters, HTML/JS and Markdown stripping—and retrieval, neutralising imperative instructions embedded in retrieved documents. Its design carries a measured lesson: an earlier revision matched blocked phrases anywhere in a sentence and consequently rewrote legitimate security prose, neutralising four lateral-movement entries (T1090, T1021, T1021.001, T1553.001) that the thesis's own APT scenarios depend on. Restricting matches to **imperative position** eliminated this, and re-verification over the current 433-entry knowledge base yields **zero** false neutralisations—the same block-rate-versus-false-flag discipline applied to a layer that publishes no ratio. The `FeedbackValidator` closes the loop opened by the Tier 2 to Tier 1 feedback mechanism of Section 4.2: rules promoted from adjudications pass a field allowlist, pattern validation, and score bounds, because a mechanism that learns from verdicts is also a mechanism for poisoning Tier 1 rules. The `DecisionValidator` enforces the output schema, salvages malformed fields by regular expres-

sion, and requires **Tier 1 concurrence** before any autonomous block. A loop detector caps node revisits at ten to stop an agent from circling and consuming GPU time, and an output sanitiser strips base64 and hexadecimal blobs before records reach the database or the dashboard, closing the re-emission path back through the analyst interface.

Field position, tested separately. Because nonce encapsulation wraps **per field**, field position decides whether a payload falls inside or outside the wrapped region—a property no aggregate figure can test, since the other categories all place their payload in the same field. The `field_injection` set of 100 published samples distributes payloads across four positions: URI 24, User-Agent 23, message 30, payload 23. The static layer blocks only 12 of 100, as expected for plain-language injection carrying neither encoding nor delimiters. Run through Tier 2 at **100% coverage**, all 100 resisted, and the outcome is **uniform across positions**—24/24, 23/23, 30/30, 23/23—with adjudications distributed as 73 BLOCK_IP and 27 ALERT, none degraded to a permissive action. The uniformity is the finding rather than the total: had encapsulation been applied to some fields and not others, the unwrapped positions would have surfaced here as a gap. Reported separately from the 678, because it answers a different question.

4.4 RQ3 — Stateful Reasoning and Attribution

RQ3 has four components: ATT&CK technique attribution, knowledge retrieval, transparent reporting, and analyst workload reduction.

Reasoning quality. Agent adjudications are graded by a **cross-family judge** (Meta-Llama-3-8B-Instruct scoring Foundation-Sec-8B-Instruct) on a 1–5 scale, following the recommended protocol for eliminating Self-Enhancement Bias [26]. Across 277 events escalated to Tier 2, the four axes score: context precision **2.68**; answer relevancy **4.22**; faithfulness **3.88**; context recall **4.13**; mean **3.73/5.0**. Evidence grounding—the proportion of justifications containing at least one *field = value* pair matching an actual log value—reaches **50.2%** (95% CI: 44.3–56.0), averaging 1.7 citations per adjudication.

Three qualifications must accompany these figures. First, **context precision at 2.68 is a clear weakness**: retrieved documents frequently contain irrelevant entries, indicating the bottleneck lies in retrieval rather than generation. Second, this run recorded **69 of 277 adjudications missing a required field**, and the evaluation script raised its own validity flag—these numbers are therefore directional indicators, not settled conclusions. Third, the thesis **does not report** an exact-match ATT&CK attribution rate for this round, because the available attribution result files predate the author-composed-sample exclusion convention and contradict one another; citing them would violate the measurement principle established in Section 4.1. Every attribution figure in this domain must in any case be read against a floor rather than zero: within the 250-sample genuine attribution set, technique T1595.003 accounts for 130 samples, so a system always answering that identifier already scores **52%**.

Knowledge retrieval and the anchoring guardrail. The knowledge base comprises 433 STIX-structured MITRE ATT&CK entries retrieved via RRF fusion of FAISS and BM25. The evidence-anchoring guardrail (Section 3.4) requires every emitted technique identifier to appear in that batch’s retrieved documents; violations are forced to N/A and routed to `AWAIT_HITL`. Its academic value is that it **does not depend on any particular model’s propensity to hallucinate**: substituting a different model leaves the constraint fully in force.

Division of labour between tiers. A seemingly negative result confirms the design: on the non-NetFlow sample group (CSIC web attacks, zero-day, DAPT), the ML Gate attains only **11.1% Recall**, and 305 of the full set’s 336 misses fall entirely within this group. The cause is architectural rather than defective—the ML Gate is trained on **flow features**, whereas web attacks reside in the **payload**, which is exactly the work assigned to Tier 2 and the signature set. The methodological consequence is that the aggregate Recall of 0.755 mixes two non-additive populations and must be reported separately. Relatedly, and as stated in Section 3.3, the escalation-to-analyst rate is **not** a quantity to be minimised: an architecture claiming a zero human-review rate under all conditions has discarded its final guardrail.

Chapter 5

Conclusion and Future Work

This chapter synthesizes the research outcomes and contributions of the thesis, affirms its scientific and practical value, analyses architectural limitations, and outlines a development roadmap.

5.1 Summary of Research Achievements

On RQ1, measurements confirm that the tiered architecture resolves the resource consumption problem inherent in language models. On the benchmark stream of 25,649 events at a 31.6% attack rate, Tier 1 and the Machine Learning Gate resolve **90.6%** of traffic without a single LLM invocation; on a 99,717-event stream at a more realistic 9.8% attack rate, that figure reaches **97.5%**. The research establishes that offload is a **function of the stream’s attack base rate** rather than a constant of the system: within each stream the aggregate decomposes linearly into a benign-case and an attack-case rate—92.35% and 86.72% on the benchmark stream, 97.88% and 93.77% on the SOC-like stream—so the relation licenses projection to a different base rate within a stream, not transfer between streams. The ML Gate processes each vector in 0.287 ms (3,452 events/second), the semantic cache achieves an 81.3% hit rate with an $8.9\times$ speed-up, and the Tier 2 to Tier 1 feedback loop absorbs a further 11.35% of escalation load *while simultaneously* improving detection quality (MCC +0.0378). End-to-end, mean latency falls from **17,187.9 ms** to **5,286.7 ms** (−69.2%, Mann-Whitney $p \approx 9 \times 10^{-57}$) and the median from 17,174.7 ms to **0.88 ms**. The thesis equally reports the counter-result: the 95th percentile is **worse** (25,829 ms versus 21,434 ms), because an escalated event pays the Tier 1 and ML Gate cost before the LLM cost. The benefit is concentrated in the median, not distributed uni-

formly.

On RQ2, the HMAC-SHA256 chain detects **100%** of the three core tampering modes—content edit, forged-record insertion, and middle-record deletion—across 30 trials each, with a negative control over 450 intact records producing no false alarm. The guarantee’s scope is stated precisely: because the key is symmetric, the mechanism ensures **integrity and tamper-evidence**, not cryptographic non-repudiation; and **tail truncation is a blind spot in principle**. The system is evaluated against two distinct adversarial surfaces. Against attacks **through language**, the static pre-filter blocks 18.8% of 703 published samples—alongside a 20.0% false-flag rate on benign logs concentrated entirely in the encoding-detection layer—while Tier 2, evaluated at **100% coverage** of the 678 samples in the categories that layer does not absorb, resisted **678 of 678**. Against attacks **through feature space**, where extreme values are injected to force the ML Gate toward "benign", resistance reaches **98.75%** under the hard mode that distorts every feature (1,023 of 1,036; 95% CI 97.86–99.27). This supports the central claim: the guarantee comes from **Delimited Data Encapsulation**, which treats encapsulated content as passive text regardless of what it says and therefore does not depend on any classifier’s ability to recognise malicious content. Robustness controls confirm the agent is deterministic under a fixed seed and flips no adjudication under seed-only variation, so measured differences between configurations are not decoder noise.

On RQ3, the Tier 2 LangGraph agent with Dual-RAG over 433 STIX-structured ATT&CK entries, graded by a cross-family judge (Meta-Llama-3-8B) across 277 escalated events, attains a mean of **3.73/5.0** with relevancy 4.22 and faithfulness 3.88, while **context precision at 2.68 is a clear weakness** locating the bottleneck in retrieval; evidence grounding reaches 50.2%. The architectural contribution is the **deterministic RAG-anchoring guardrail**: every emitted technique identifier must appear in that batch’s retrieved documents, failing which it is forced to N/A and routed to an analyst—converting hallucination control from a hope placed in the model into a verifiable constraint that survives model replacement. The thesis **does not report** an exact-match ATT&CK attribution rate for this round, because the available result files predate the author-composed-sample exclusion convention

and contradict one another.

5.2 Scientific and Practical Contributions

In terms of **scientific contributions**, the thesis proposes and quantifies the principle of *placing cheap decisions before expensive ones*, addressing the quadratic $\mathcal{O}(N^2)$ latency barrier of language models on continuous telemetry [18]. The accompanying methodological contribution is the explicit statement that **offload rate is a function of base rate**, together with the linear relation permitting transfer to environments with different attack proportions—something a single headline figure cannot support. Second, it contributes a data isolation model using cryptographic nonces, providing a **structural** guarantee independent of probabilistic classifiers whose effectiveness degrades against novel variants [9, 30]. Third, it establishes a measurement convention set for local agentic security systems: denominators matched to questions, base-rate-immune metrics, exclusion of author-composed samples from published ratios, and mandatory reporting of block rates alongside false-flag rates.

In terms of **practical contributions**, the thesis delivers a complete prototype packaged via Docker Compose and verified on accessible commercial hardware (Intel Core i7, 32 GB RAM, a single RTX 4060 Ti 16 GB VRAM GPU), adhering to Zero-Trust principles in an air-gapped environment [31], with a Streamlit dashboard connected to Human-in-the-Loop queues replacing static SOAR playbooks [5] and forensic trails sealed by HMAC-SHA256 chaining [29].

5.3 Limitations and Future Directions

Four limitations are stated below, each paired with its corresponding remediation.

First—log source coverage. Evaluation currently focuses on normalized NetFlow features and Layer-7 HTTP logs [1, 27]. Unstructured sources (Windows Event Logs, raw Syslog, AWS CloudTrail) require more sophisticated parsing. The remediation is an ingestion en-

engine integrating log template clustering such as Drain [22] to normalize arbitrary formats into standard feature vectors before the pipeline.

Second—single-node throughput ceiling. Above 100,000 events/second, the volume escalating to Tier 2 on a single 16 GB GPU may exceed immediate inference capacity, causing queue accumulation. The remediation is to reimplement Tier 1 filters in a compiled systems language (Go or Rust), migrate Redis Streams to partitioned disk-backed Apache Kafka, and upgrade Tier 2 to vLLM or TGI supporting PagedAttention and continuous batching.

Third—technique attribution and retrieval quality. The context precision score of 2.68 indicates the retrieval layer admits substantial irrelevant material; the reasoning quality run additionally recorded 69 of 277 adjudications missing a required field, rendering it directional only. Remediations include re-measuring attribution under the standardized convention with the 52% random-guess floor stated alongside, adding retrieval metrics (recall@ k , MRR) to separate retrieval failures from generation failures, and validating the LLM judge’s reliability via Cohen’s κ against human scoring.

Fourth—attack chain correlation and self-DoS. Behavioural correlation currently relies on fixed source IP addresses, so under IP rotation or distributed botnets its effectiveness would degrade. Concurrently, to avoid mistakenly blocking internal infrastructure, the system routes adjudications resting on generic rules to the analyst queue, accepting reduced automation. The remediation is correlation based on **technique vectors** rather than source addresses, combined with Graph Neural Networks, and Reinforcement Learning from Human Feedback over approval decisions in the `AWAIT_HITL` queue to progressively automate safely.

Beyond these four, the longer-term roadmap includes upgrading the sealing chain to asymmetric signatures (Ed25519) to achieve genuine non-repudiation, periodically anchoring hash values outside the system to close the tail-truncation blind spot, and integrating the Model Context Protocol so agents can dynamically orchestrate external security tooling.

Concluding a rigorous research endeavor, while opening inspiring horizons in securing the digital realm through the power of Agentic Artificial Intelligence.

References

- [1] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization," in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [2] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, "Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures," *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [3] R. Zuech, T. M. Khoshgoftaar, and R. Wald, "Intrusion Detection and Big Heterogeneous Data: A Survey," *Journal of Big Data*, vol. 2, art. 3, 2015.
- [4] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, "Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities," *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [5] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, "Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence," *Information*, vol. 16, no. 5, art. 365, 2025.
- [6] B. P. Welford, "Note on a Method for Calculating Corrected Sums of Squares and Products," *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
- [7] P. Lewis *et al.*, "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks," *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
- [8] LangChain AI, "LangGraph: Multi-Actor, Stateful LLM Applications," *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
- [9] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, "More than you've asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models," *arXiv preprint arXiv:2302.12173*, 2023.
- [10] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, "Computer Security Incident Handling Guide," NIST Special Publication 800-61 Revision 2, 2012.
- [11] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, "Reciprocal Rank Fusion Outperforms Condorcet and Individual Bootstrap Product Algorithms," in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009.
- [12] R. Pandey and A. Bhujang, "Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content," *arXiv preprint arXiv:2605.24421*, 2026.
- [13] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, "CyberRAG: An Agentic RAG cyber attack classification and reporting tool," *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
- [14] Z. Liu and A. Anwar, "AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation," *arXiv preprint arXiv:2508.13118*, 2025.
- [15] J. Zhang *et al.*, "When LLMs Meet Cybersecurity: A Systematic Literature Review,"

- Cybersecurity*, vol. 8, 2025.
- [16] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, “LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations,” *arXiv preprint arXiv:2604.05440*, 2026.
 - [17] R. Sahay *et al.*, “Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage,” *arXiv preprint arXiv:2603.23966*, 2026.
 - [18] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
 - [19] A. Gholami *et al.*, “A Survey of Quantization Methods for Efficient Neural Network Inference,” *arXiv preprint arXiv:2103.13630*, 2021.
 - [20] J. Johnson, M. Douze, and H. Jégou, “Billion-Scale Similarity Search with GPUs,” *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2019.
 - [21] S. Robertson and H. Zaragoza, “The Probabilistic Relevance Framework: BM25 and Beyond,” *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–380, 2009.
 - [22] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, “Drain: An Online Log Parsing Approach with Fixed Depth Tree,” in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
 - [23] Cybersecurity Research Team, “Foundation-Sec: An Open LLM for Cyber Threat Detection,” *Security Preprint*, 2024.
 - [24] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, “MITRE ATT&CK: Design and Philosophy,” The MITRE Corporation, Technical Report MP180360, 2018.
 - [25] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
 - [26] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.
 - [27] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
 - [28] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
 - [29] H. Krawczyk, M. Bellare, and R. Canetti, “HMAC: Keyed-Hashing for Message Authentication,” Internet Engineering Task Force, RFC 2104, 1997.
 - [30] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
 - [31] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
 - [32] A. Zou, Z. Wang, J. Z. Kolter, and M. Fredrikson, “Universal and Transferable Adversarial Attacks on Aligned Language Models,” *arXiv preprint arXiv:2307.15043*, 2023.
 - [33] J. Hao *et al.*, “Jailbreak Prompts on Large Language Models,” *GitHub repository*, 2023. [Online]. Available: https://github.com/verazuojailbreak_llms
 - [34] Deepset, “Prompt Injections Dataset,” *Hugging Face repository*, 2023. [Online].

Available: <https://huggingface.co/datasets/deepset/prompt-injections>